



UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

**Nombre Del Alumno:
Alejandro Contreras Martinez**

**Docente:
José Miguel Carrera Pacheco**

**Arquitectura de autenticación
y control de roles**

**ING EN
DESARROLLO DE
SOFTWARE
MULTIPLATAFORMA**

¿Qué es autenticación y en qué se diferencia de autorización?

- La autenticación es el proceso de confirmar la identidad de un usuario. Este suele ser el paso inicial en el proceso de seguridad. Para confirmar la identidad del usuario, el usuario debe presentar evidencia (información) física o no física a la plataforma de autenticación.
- La autorización es el proceso de dar permiso a un usuario para acceder a una ubicación física o recurso basado en información

La autenticación es un proceso para autenticar a un usuario, es decir, para verificar que alguien es quien dice ser. La autorización consiste en determinar el nivel de acceso de un usuario y luego otorgar acceso en función de ese nivel.

¿Qué son JWT, sesiones y OAuth?

- **JWT: Tokens de autenticación autónomos**

A JSON Web Token (JWT) es un formato compacto y sin estado que permite a los usuarios autenticar y llevar las reclamaciones necesarias sin depender de sesiones en el lado del servidor.

Los JWT son geniales para arquitecturas distribuidas y microservicios. Son fáciles de verificar, fáciles de transmitir entre plataformas y no requieren gestión de estado en el lado del servidor, lo que los hace ideales para escalar la autenticación en sistemas modernos.

Un JWT consta de tres partes distintas:

1. **Cabecera** - Contiene metadatos sobre el tipo de token y el algoritmo de firma que se está utilizando (por ejemplo, HMAC SHA256 o RSA).
2. **Carga útil** - Contiene afirmaciones sobre la entidad (normalmente el usuario) y datos adicionales. Las reclamaciones pueden incluir ID de usuario, roles, permisos y tiempo de caducidad del token.
3. **Firma** - Creada combinando el encabezado codificado, la carga útil codificada y una clave secreta usando el algoritmo especificado en el encabezado. Esto asegura que el token no haya sido manipulado.

- **Sesiones**

Una sesión es un mecanismo del lado del servidor que almacena los datos del usuario durante su interacción con una aplicación web. Cuando un usuario inicia sesión, el servidor genera un ID de sesión único, que se envía al cliente

como una cookie. El servidor mantiene el estado de la sesión, lo que le permite rastrear las interacciones del usuario a través de múltiples solicitudes.

- **OAuth.**

OAuth es un marco de autorización diseñado para delegar acceso a recursos sin exponer las credenciales de usuario, permitiendo un acceso seguro y limitado entre aplicaciones. OAuth define una forma estandarizada de autorizar aplicaciones de terceros y gestionar permisos utilizando tokens de acceso y alcances. Es la columna vertebral de integraciones seguras—desde APIs empresariales hasta sistemas de inicio de sesión social.

¿Cuándo conviene usar tokens y cuándo sesiones?

Para la autenticación de sesiones se pueden utilizar suele ser adecuada para sitios web en el mismo dominio raíz.

Para la autenticación de autenticación por token este método de autenticación es más adecuado para aplicaciones móviles o aplicaciones web de una sola página. El mecanismo clave de transporte aquí es el token de acceso en la cabecera de autorización.

Ambas pueden ser utilizadas pero ahí factores donde son mejores la autorización de usar tokens y cuándo sesiones como lo pueden ser:

Aspecto	Sesiones	Tokens
Estado	El servidor almacena una sesión (ID en la cookie).	El cliente posee un token de acceso (JWT u opaco).
Almacenamiento	HttpOnly, cookies.SameSite	Prefiero cookies; Evita tokens de larga duración en el almacenamiento JS.HttpOnly
Escalabilidad	Necesita almacenamiento y replicación de sesiones compartidas	Sin estado ajusta APIs; Los tokens opacos pueden necesitar introspección
Úsalo cuando...	Aplicaciones web de dominio único, flujos renderizados por servidor.	APIs, SPAs, móviles, multidominio o microservicios.

¿Qué riesgos de seguridad existen en un mal diseño de autenticación?

Las vulnerabilidades de autenticación son problemas que afectan a los procesos de autenticación y hacen que sitios web y aplicaciones sean susceptibles a ataques de seguridad en los que un atacante puede hacerse pasar por un usuario legítimo.

La autenticación es una parte vital de cualquier sitio web o aplicación, ya que es simplemente el proceso de reconocer la identidad de los usuarios.

Los usuarios maliciosos pueden utilizar estas vulnerabilidades para acceder a sistemas y cuentas de usuario para:

- Robar información sensible
- Hacerse pasar por un usuario legítimo
- Obtener el control de la aplicación
- Destruir el sistema por completo

Si los atacantes pueden pasar ilegalmente por el proceso de autenticación y acceder a una cuenta de usuario, pueden robar datos críticos como nombres, datos de tarjetas de crédito, números de la seguridad social (SSN), historiales médicos y identificaciones fiscales. También pueden tomar acciones en nombre del usuario, como iniciar transacciones financieras, eliminar datos o transferir la propiedad de los recursos.

¿Cómo se definen roles y permisos en sistemas reales?

Los roles se pueden definir a través de un sistema de control de acceso basado en roles el cual es un método de seguridad que gestiona el acceso a sistemas informáticos y datos en función del papel del usuario dentro de una organización. Así es como funciona:

- Roles: Define diferentes funciones laborales dentro del sistema. Ejemplos podrían ser "administrador", "editor" o "lector". Cada rol tiene un conjunto específico de permisos asociados.
- Permisos: Especifica las acciones que un usuario puede realizar dentro del sistema. Esto puede ser ver archivos, editar documentos o aprobar transacciones.

- Usuarios: Asignados uno o más roles según sus responsabilidades laborales. Los permisos de un usuario se determinan por la combinación de los roles asignados.

Bibliography

Bratslavsky, P. (2025, apr 11). Obtenido de <https://strapi.io/blog/jwt-vs-oauth>

Fortinet. (s.f.). Recuperado el 03 08, 2026, de <https://www.fortinet.com/lat/resources/cyberglossary/authentication-vs-authorization>

Medium. (s.f.). Recuperado el 03 08, 2026, de <https://master-springter.medium.com/session-jwt-token-sso-and-oauth-2-0-a-comprehensive-guide-with-examples-b07a92de3f6e>

Nason, A. (s.f.). Recuperado el 03 08, 2026, de <https://www.coro.net/blog/the-importance-of-user-roles-and-permissions-in-cybersecurity-software>